

ISO/IEC 27001:2022 System Assurance & Control Implementation Report

System-specific control applicability, implementation, evidence, risks, and supplemental assurance.

Production AI Platform

SYSTEM IDENTIFIER	SYS-003
ENVIRONMENT	Production - AWS
CLASSIFICATION	Restricted
REPORT DATE	2026-08-19
SOURCE STATE	Application facts and derived assurance as of 2026-08-19

Purpose and limitation

This system-level report supports ISO/IEC 27001 readiness and assurance activities. It is not an ISO certificate, a complete organizational Statement of Applicability, or proof of conformity. ISO references identify mappings recorded in this application; ACME-authored control names and implementation evidence remain the substantive basis of each entry.

1. Executive Assurance Summary

A concise view of assessed posture, coverage, evidence, risk, and unresolved action.

CURRENT ASSURANCE 63 Target 100	ASSESSMENT COVERAGE 43% 120 of 282 applicable controls	EVIDENCE COVERAGE 41% 103 of 254 required instances	ABOVE APPETITE 9 14 mapped risk scenarios
ISO-MAPPED CONTROLS 202 Applicable controls with ISO 27001 mappings	ISO ASSESSED 94 108 remain outside assessment scope	OPEN FINDINGS 3 0 overdue	STALE EVIDENCE 32 Evidence instances marked stale

Assurance scores describe the assessed population. Assessment coverage separately states how much of the applicable control population was assessed. Controls that are not assessed or unassessed controls are not scored as zero.

2. System Scope and Context

The system boundary and operating context used for this report.

MISSION	ACME's core AI product platform - the model-serving, retrieval-augmented generation (RAG), and API layer that powers ACME's customer-facing AI features, from the public ingress point down through the customer data it draws on to answer queries.
BOUNDARY	Runs entirely within a dedicated AWS production account, network-isolated from ACME's corporate network and other AWS accounts. The boundary covers the API gateway, model-serving and RAG compute, the vector store, and the encrypted customer data and metadata stores backing them; the upstream applications that call this platform's API are separately owned systems outside this boundary.
HOSTING	Cloud - AWS
AVAILABILITY TIER	Tier 1 Critical
REGIONS	us-east-1, us-west-2
USERS	1,842
STANDARDS RECORDED	SOC 2, ISO 27001, ISO 42001
LAST SYNCHRONIZED	8 min ago via vanta

Role	Accountable party	Note
System Owner	ML Platform Team	
Technical Administrator	ML Platform Team	AWS environment specifically.
Security Owner	IT Security	
Data Owner	Product Leadership	

3. Information and Asset Profile

Data handled by this boundary and the assets that process, store, protect, or recover it.

DATA SUBJECTS	Customers, End Users
APPROXIMATE RECORDS	4,200,000
RETENTION	7 years post-contract-termination
RESIDENCY	United States

Data type	Sensitivity	Regulatory flags
Customer PII	Restricted	PII
Customer Documents	Restricted	None recorded
Model Prompts & Outputs	Restricted	PII
Encryption Keys & Secrets	Restricted	Credentials
Session & Usage Metadata	Confidential	None recorded
Access & Audit Logs	Confidential	Employee-Data
Deployment Artifacts & CI/CD Credentials	Confidential	Credentials

Asset	Type	Provider	Classification
Web Application Firewall	AWS WAF	AWS	Restricted
API Gateway	AWS API Gateway	AWS	Restricted
Agent Runtime / Orchestrator	AWS ECS Service (Fargate)	AWS	Restricted
RAG Retrieval Service	AWS ECS Service (Fargate)	AWS	Restricted
Vector Database	Amazon OpenSearch Service (Vector Engine)	AWS	Restricted
prod-customer-data S3	AWS S3 Bucket	AWS	Restricted
RDS Metadata Database	AWS RDS (PostgreSQL)	AWS	Restricted
KMS Key	AWS KMS Key	AWS	Restricted
Secrets Manager	AWS Secrets Manager	AWS	Restricted
Partner Integration Delivery	AWS API Gateway	AWS	Restricted
AI / Model Gateway	Internal Model Routing Gateway	AWS	Restricted
Agent Policy / Authorization Service	Deterministic Policy Decision Point	AWS	Confidential
Tool / MCP Gateway	Agent Tool-Call Gateway	AWS	Restricted
Agent Session Cache	Amazon ElastiCache (Redis)	AWS	Confidential
Secure Egress Gateway	AWS Network Firewall / Secure Proxy	AWS	Restricted
Identity & Workload IAM	AWS IAM / STS	AWS	Restricted
Security & AI Telemetry	Centralized Log & Telemetry Pipeline	AWS	Confidential
SIEM / Security Monitoring	Splunk	Splunk	Confidential
Runtime Security	Amazon GuardDuty Runtime Monitoring	AWS	Confidential
CI/CD Pipeline	GitHub Actions / AWS CodeDeploy	AWS	Confidential
Container Image Registry	Amazon ECR	AWS	Confidential
Infrastructure-as-Code Pipeline	Terraform Cloud	Terraform Cloud	Confidential
Okta	Okta Workforce Identity Cloud	Okta	Restricted
Zscaler	Zscaler Private Access (ZTNA)	Zscaler	Restricted

Asset	Type	Provider	Classification
Immutable Backup Vault	AWS Backup Vault (Cross-Region Copy)	AWS	Restricted

4. Architecture and Dependencies

Recorded boundary connections and third-party dependencies; consult the live Architecture tab for topology and data-flow diagrams.

- Inbound: authenticated API calls from ACME's customer-facing applications via API Gateway
- Internal: model-serving calls the RAG service, which queries the vector database and metadata store
- Encryption: all data at rest protected by a dedicated KMS key; service credentials brokered through Secrets Manager

Dependency	Criticality	Reassessed	Shared responsibility
AWS	critical	2026-02-14	Reviewed
External Model Provider	critical	2025-06-10	Not reviewed

5. Operational Assurance

Identity, exposure, testing, incident response, and recovery signals supporting control operation.

Domain	Indicator	Current state
Identity	Tracked identities	85; 2 dormant; 0 awaiting termination
Agentic identity	Registered agents	4; 3 with issues; 1 long-lived API keys
Access review	Latest review	2026-06-15; 85/85; 1 exceptions
Exposure	Externally reachable services	2; 0 unmitigated dangerous conditions
Security testing	Cadence	Required exercises current
Incident response	Plan and tabletop	Plan review current; tabletop current
Backup	Coverage and immutability	100% coverage; immutable
Recovery	Latest exercise	2026-03-20; targets met

6. Risk Context

Highest residual risk scenarios mapped to assets and controls in this system.

Scenario	Owner	Residual	Appetite	Control assurance
Cross-tenant data exposure through authorization defect	Platform Eng	Severe / Likely	2x	55
Model Distillation & IP Theft	ML Platform Team	Severe / Likely	3.2x	56
AI agent causes large-scale unauthorized actions	ML Platform Team	Severe / Possible	2.4x	52
Systemic corruption/poisoning of the core model	ML Platform Team	Severe / Possible	2.4x	60
Extended loss of the production AI platform	Infrastructure	Severe / Possible	2x	50

7. ISO/IEC 27001:2022 Control Implementation

Applicable system controls mapped to ISO 27001 clauses. Control names and explanations are ACME-authored; clause identifiers are cross-reference metadata.

CATALOG APPLICABILITY	282 applicable, 35 not applicable, 6 pending across the in-scope catalog
RESPONSIBILITY SPLIT	136 owned, 41 shared, 87 enterprise, 18 vendor

AST-01 - Asset Governance

ISO clauses: 5.30, 5.31, 7.9, 5.9, 4.2, 4.2(a) | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-01; its Internal attestation type-1 covers "Asset Management".

AST-02 - Asset Inventories

ISO clauses: 5.9, 5.32, 8.9 | Domain: Asset Management | Status: Satisfied | Responsibility: Enterprise | Assurance: 65 | Evidence records: 0
1 of 1 instance verified. Worst result from Asset inventory reconciliation.

AST-03 - Asset Ownership Assignment

ISO clauses: 5.9, 5.21 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-03; its Internal attestation type-1 covers "Asset Management".

AST-04 - Network Diagrams & Data Flow Diagrams (DFDs)

ISO clauses: 5.9, 8.20, 4.3, 5.12 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-04; its Internal attestation type-1 covers "Asset Management".

AST-05 - Security of Assets & Media

ISO clauses: 7.9 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 48 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-05; its Internal attestation type-1 covers "Asset Management".

AST-06 - Unattended End-User Equipment

ISO clauses: 7.7, 7.9, 8.1 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-06; its Internal attestation type-1 covers "Asset Management".

AST-07 - Kiosks & Point of Interaction (PoI) Devices

ISO clauses: 8.1 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-07; its Internal attestation type-1 covers "Asset Management".

AST-08 - Physical Tampering Detection

ISO clauses: 7.9 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 48 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-08; its Internal attestation type-1 covers "Asset Management".

AST-09 - Secure Disposal, Destruction or Re-Use of Equipment

ISO clauses: 7.14, 8.10 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-09; its Internal attestation type-1 covers "Asset Management".

AST-10 - Return of Assets

ISO clauses: 5.11 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-10; its Internal attestation type-1 covers "Asset Management".

AST-11 - Removal of Assets

ISO clauses: 7.10 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 48 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-11; its Internal attestation type-1 covers "Asset Management".

AST-12 - Use of Personal Devices

ISO clauses: 7.10, 8.1 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-12; its Internal attestation type-1 covers "Asset Management".

AST-15 - Logical Tampering Protection

ISO clauses: 7.9 | Domain: Asset Management | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0
Enterprise IT Asset Management Program operates AST-15; its Internal attestation type-1 covers "Asset Management".

BCD-01 - Business Continuity Management System (BCMS)

ISO clauses: 5.29, 5.30 | Domain: Business Continuity & Disaster Recovery | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

BCD-04 - Contingency Plan Testing & Exercises

ISO clauses: 5.29, 5.30 | Domain: Business Continuity & Disaster Recovery | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

BCD-08 - Alternate Storage Site

ISO clauses: 8.14 | Domain: Business Continuity & Disaster Recovery | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

BCD-09 - Alternate Processing Site

ISO clauses: 8.14 | Domain: Business Continuity & Disaster Recovery | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

BCD-11 - Data Backups

ISO clauses: 8.13, 8.14 | Domain: Business Continuity & Disaster Recovery | Status: Partial | Responsibility: Internal | Assurance: 54 | Evidence records: 3
0 of 4 instances verified, 3 partial, 1 with no evidence collected. Worst result from Vector store snapshot configuration.

CAP-01 - Capacity & Performance Management

ISO clauses: 8.6 | Domain: Capacity & Performance Planning | Status: Partial | Responsibility: Internal | Assurance: 46 | Evidence records: 5
0 of 5 instances verified, 5 partial. Worst result from Azure Monitor / CloudWatch capacity telemetry.

CAP-03 - Capacity Planning

ISO clauses: 8.6 | Domain: Capacity & Performance Planning | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CHG-01 - Change Management Program

ISO clauses: 6.3, 8.19, 8.32 | Domain: Change Management | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CHG-02 - Configuration Change Control

ISO clauses: 8.19, 8.32 | Domain: Change Management | Status: Deficient | Responsibility: Shared | Assurance: 45 | Evidence records: 8
0 of 25 instances verified, 8 partial, 17 with no evidence collected.

CLD-01 - Cloud Services

ISO clauses: 5.23 | Domain: Cloud Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CLD-02 - Cloud Security Architecture

ISO clauses: 5.23 | Domain: Cloud Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CLD-04 - Application Programming Interface (API) Security

ISO clauses: 5.23, 8.26 | Domain: Cloud Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CLD-06 - Multi-Tenant Environments

ISO clauses: 5.23, 4.3(c) | Domain: Cloud Security | Status: Partial | Responsibility: Shared | Assurance: 65 | Evidence records: 5

3 of 6 instances verified, 1 partial, 1 not implemented, 1 with no evidence collected. Worst result from Automated cross-tenant access test.

CLD-09 - Geolocation Requirements for Processing, Storage and Service Locations

ISO clauses: 5.23 | Domain: Cloud Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CPL-01 - Statutory, Regulatory & Contractual Compliance

ISO clauses: 4.1, 9.1, 9.2.1, 9.2.2, 5.31, 8.34, 9.1(a), 9.1(b), 9.1(c), 9.1(d), 9.1(e), 9.1(f), 10.2, 10.2(a), 10.2(a)(1), 10.2(a)(2), 10.2(b), 10.2(b)(1), 10.2(b)(2), 10.2(b)(3), 10.2(c), 10.2(d), 10.2(e), 10.2(f), 10.2(g), 4.3, 4.3(a), 4.3(b), 4.3(c) | Domain: Compliance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CPL-02 - Security, Compliance & Resilience Controls Oversight

ISO clauses: 8.1, 10.1, 5.31, 5.36, 6.8, 8.8, 8.34, 9.2.1, 9.2.1(a)(1), 9.2.1(a)(2), 9.2.1(b), 9.2.2, 9.2.2(a), 9.2.2(b), 9.2.2(c), 5.35 | Domain: Compliance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CPL-03 - Security, Compliance & Resilience Assessments

ISO clauses: 8.1, 9.1, 9.1(a), 9.1(b), 9.1(c), 9.1(d), 9.1(e), 9.1(f), 5.35, 5.36, 8.34, 8.8 | Domain: Compliance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CPL-04 - Audit Activities

ISO clauses: 5.35, 8.34 | Domain: Compliance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CFG-01 - Configuration Management Program

ISO clauses: 8.3, 8.9, 8.12 | Domain: Configuration Management | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CFG-02 - Secure Baseline Configurations

ISO clauses: 8.3, 8.5, 8.9, 8.12, 8.25, 8.26 | Domain: Configuration Management | Status: Deficient | Responsibility: Vendor | Assurance: 43 | Evidence records: 7

2 of 25 instances verified, 5 partial, 18 with no evidence collected. Worst result from OpenSearch domain configuration review.

CFG-03 - Least Functionality

ISO clauses: 8.3, 8.9, 8.12, 8.8, 8.27 | Domain: Configuration Management | Status: Partial | Responsibility: Shared | Assurance: 70 | Evidence records: 5

4 of 5 instances verified, 1 partial. Worst result from RAG service task definition review.

MON-01 - Continuous Monitoring

ISO clauses: 8.15, 8.16 | Domain: Continuous Monitoring | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0
Enterprise Security Operations Program operates MON-01; its Internal attestation Type II covers "Continuous Monitoring".

MON-02 - Centralized Collection of Security Event Logs

ISO clauses: 8.15, 6.8, 8.16 | Domain: Continuous Monitoring | Status: Deficient | Responsibility: Enterprise | Assurance: 58 | Evidence records: 8

0 of 25 instances verified, 8 partial, 17 with no evidence collected. Worst result from Microsoft Sentinel ingestion telemetry.

MON-03 - Content of Event Logs

ISO clauses: 8.15 | Domain: Continuous Monitoring | Status: Deficient | Responsibility: Enterprise | Assurance: 63 | Evidence records: 6
4 of 25 instances verified, 2 partial, 19 with no evidence collected. Worst result from Sentinel log schema conformance test.

MON-06 - Monitoring Reporting

ISO clauses: 6.8, 8.15 | Domain: Continuous Monitoring | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0
Enterprise Security Operations Program operates MON-06; its Internal attestation Type II covers "Continuous Monitoring".

MON-08 - Protection of Event Logs

ISO clauses: 8.15 | Domain: Continuous Monitoring | Status: Partial | Responsibility: Enterprise | Assurance: 73 | Evidence records: 2
2 of 3 instances verified, 1 with no evidence collected.

MON-11 - Monitoring For Information Disclosure

ISO clauses: 5.7 | Domain: Continuous Monitoring | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0
Enterprise Security Operations Program operates MON-11; its Internal attestation Type II covers "Continuous Monitoring".

CRY-01 - Use of Cryptographic Controls

ISO clauses: 8.24, 8.26, 5.31 | Domain: Cryptographic Protections | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CRY-03 - Transmission Confidentiality

ISO clauses: 5.14, 8.24, 8.26 | Domain: Cryptographic Protections | Status: Deficient | Responsibility: Shared | Assurance: 45 | Evidence records: 6
6 of 25 instances verified, 19 with no evidence collected.

CRY-04 - Transmission Integrity

ISO clauses: 8.24, 8.26 | Domain: Cryptographic Protections | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

CRY-05 - Encrypting Data At Rest

ISO clauses: 8.24 | Domain: Cryptographic Protections | Status: Partial | Responsibility: Shared | Assurance: 65 | Evidence records: 5
5 of 6 instances verified, 1 with no evidence collected.

CRY-09 - Cryptographic Key Management

ISO clauses: 8.24 | Domain: Cryptographic Protections | Status: Partial | Responsibility: Shared | Assurance: 65 | Evidence records: 5
4 of 6 instances verified, 1 partial, 1 with no evidence collected.

DCH-01 - Data Protection

ISO clauses: 5.9, 5.10, 5.12, 5.33, 7.10, 8.12 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-02 - Data & Asset Classification

ISO clauses: 5.9, 5.12 | Domain: Data Classification & Handling | Status: Partial | Responsibility: Internal | Assurance: 55 | Evidence records: 0
0 of 1 instance verified, 1 partial. Worst result from Data classification policy attestation.

DCH-03 - Media Access

ISO clauses: 7.10, 8.11 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-04 - Media Marking

ISO clauses: 5.10, 5.13 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-06 - Media Storage

ISO clauses: 7.10 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-07 - Media Transportation

ISO clauses: 5.14, 7.10, 5.10 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-08 - Physical Media Disposal

ISO clauses: 7.10, 8.10 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-09 - System Media Sanitization

ISO clauses: 8.10 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-10 - Media Use

ISO clauses: 7.10 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-12 - Removable Media Security

ISO clauses: 7.10 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-14 - Information Sharing

ISO clauses: 5.14 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-17 - Ad-Hoc Transfers

ISO clauses: 5.14 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-18 - Media & Data Retention

ISO clauses: 5.33, 8.10 | Domain: Data Classification & Handling | Status: Partial | Responsibility: Internal | Assurance: 60 | Evidence records: 3

1 of 4 instances verified, 1 partial, 1 not implemented, 1 with no evidence collected. Worst result from Retention schedule review - vector store.

DCH-21 - Information Disposal

ISO clauses: 8.10 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

DCH-23 - De-Identification (Anonymization)

ISO clauses: 8.33, 8.11 | Domain: Data Classification & Handling | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PRI-01 - Data Privacy Program

ISO clauses: 5.1, 5.34 | Domain: Data Privacy | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PRI-02 - Data Privacy Notice

ISO clauses: 5.34 | Domain: Data Privacy | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PRI-03 - Choice & Consent

ISO clauses: 5.33 | Domain: Data Privacy | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PRI-04 - Restrict Collection To Identified Purpose

ISO clauses: 5.33 | Domain: Data Privacy | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PRI-05 - Personal Data (PD) Retention & Disposal

ISO clauses: 5.33, 8.10, 8.11, 5.9 | Domain: Data Privacy | Status: Partial | Responsibility: Internal | Assurance: 58 | Evidence records: 0

0 of 1 instance verified, 1 partial. Worst result from Personal data retention schedule review.

PRI-07 - Information Sharing With Third Parties

ISO clauses: 5.33, 5.31 | Domain: Data Privacy | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PRI-08 - Personal Data (PD) Control Testing, Training & Monitoring

ISO clauses: 5.36, 8.8 | Domain: Data Privacy | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

END-01 - Endpoint Device Management (EDM)

ISO clauses: 7.7, 8.1, 8.5 | Domain: Endpoint Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

END-02 - Endpoint Protection Measures

ISO clauses: 8.1, 8.5 | Domain: Endpoint Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

END-03 - Prohibit Installation Without Privileged Status

ISO clauses: 8.19 | Domain: Endpoint Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

END-04 - Malicious Code Protection (Anti-Malware)

ISO clauses: 8.7 | Domain: Endpoint Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

END-09 - Trusted Path

ISO clauses: 8.5 | Domain: Endpoint Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

HRS-01 - Human Resources Security Management

ISO clauses: 7.2(d), 7.3, 7.3(a), 7.3(b), 7.3(c), 5.4 | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0

Enterprise People Security Program operates HRS-01; its Internal attestation type-1 covers "Human Resources Security".

HRS-02 - Position Categorization

ISO clauses: 7.2(a) | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0

Enterprise People Security Program operates HRS-02; its Internal attestation type-1 covers "Human Resources Security".

HRS-03 - Defined Roles & Responsibilities

ISO clauses: 5.3, 7.3, 7.3(b), 5.2, 7.3(a), 7.3(c), 7.2, 7.2(a), 7.2(b), 7.2(c), 7.2(d) | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 48 | Evidence records: 0

Enterprise People Security Program operates HRS-03; its Internal attestation type-1 covers "Human Resources Security".

HRS-04 - Personnel Screening

ISO clauses: 7.2(b), 7.2(c), 6.1, 5.2, 7.3, 7.3(a), 7.3(b), 7.3(c), 5.4 | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0

Enterprise People Security Program operates HRS-04; its Internal attestation type-1 covers "Human Resources Security".

HRS-05 - Terms of Employment

ISO clauses: 7.3, 7.3(a), 7.3(b), 7.3(c), 5.4, 5.14, 6.2, 5.10 | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0

Enterprise People Security Program operates HRS-05; its Internal attestation type-1 covers "Human Resources Security".

HRS-06 - Access Agreements

ISO clauses: 5.10, 5.14, 6.6 | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 48 | Evidence records: 0

Enterprise People Security Program operates HRS-06; its Internal attestation type-1 covers "Human Resources Security".

HRS-07 - Personnel Sanctions

ISO clauses: 6.4 | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0

Enterprise People Security Program operates HRS-07; its Internal attestation type-1 covers "Human Resources Security".

HRS-08 - Personnel Transfer

ISO clauses: 6.5 | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0

Enterprise People Security Program operates HRS-08; its Internal attestation type-1 covers "Human Resources Security".

HRS-09 - Personnel Termination

ISO clauses: 6.5 | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 48 | Evidence records: 0

Enterprise People Security Program operates HRS-09; its Internal attestation type-1 covers "Human Resources Security".

HRS-11 - Separation of Duties (SoD)

ISO clauses: 5.3, 5.18 | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 58 | Evidence records: 0

Enterprise People Security Program operates HRS-11; its Internal attestation type-1 covers "Human Resources Security".

HRS-12 - Incompatible Roles

ISO clauses: 5.3 | Domain: Human Resources Security | Status: Inherited | Responsibility: Enterprise | Assurance: 48 | Evidence records: 0

Enterprise People Security Program operates HRS-12; its Internal attestation type-1 covers "Human Resources Security".

IAC-01 - Identity & Access Management (IAM)

ISO clauses: 5.15, 5.18 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 74 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-01; its Internal attestation Type II covers "Identification & Authentication".

IAC-02 - Identification & Authentication for Organizational Users

ISO clauses: 5.15 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 74 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-02; its Internal attestation Type II covers "Identification & Authentication".

IAC-03 - Identification & Authentication for Non-Organizational Users

ISO clauses: 5.16 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 64 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-03; its Internal attestation Type II covers "Identification & Authentication".

IAC-04 - Identification & Authentication for Devices

ISO clauses: 5.16 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 74 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-04; its Internal attestation Type II covers "Identification & Authentication".

IAC-05 - Identification & Authentication for Third-Party Technology Assets, Applications and/or Services (TAAS)

ISO clauses: 5.16 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 74 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-05; its Internal attestation Type II covers "Identification & Authentication".

IAC-07 - User Provisioning & De-Provisioning

ISO clauses: 5.16, 5.18 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 74 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-07; its Internal attestation Type II covers "Identification & Authentication".

IAC-08 - Role-Based Access Control (RBAC)

ISO clauses: 5.15, 8.3 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 74 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-08; its Internal attestation Type II covers "Identification & Authentication".

IAC-09 - Identifier Management (User Names)

ISO clauses: 5.16 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 64 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-09; its Internal attestation Type II covers "Identification & Authentication".

IAC-10 - Authenticator Management

ISO clauses: 5.17, 5.18 | Domain: Identification & Authentication | Status: Partial | Responsibility: Enterprise | Assurance: 59 | Evidence records: 2

0 of 2 instances verified, 2 partial.

IAC-15 - Account Management

ISO clauses: 5.15, 5.16, 5.18 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 64 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-15; its Internal attestation Type II covers "Identification & Authentication".

IAC-16 - Privileged Account Management (PAM)

ISO clauses: 5.15, 5.18, 8.2 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 74 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-16; its Internal attestation Type II covers "Identification & Authentication".

IAC-17 - Periodic Review of Account Privileges

ISO clauses: 5.15, 5.18, 8.2 | Domain: Identification & Authentication | Status: Deficient | Responsibility: Enterprise | Assurance: 51 | Evidence records: 8

0 of 25 instances verified, 8 partial, 17 with no evidence collected. Worst result from Quarterly privileged access review - internal follow-up.

IAC-18 - User Responsibilities for Account Management

ISO clauses: 5.17 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 64 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-18; its Internal attestation Type II covers "Identification & Authentication".

IAC-19 - Credential Sharing

ISO clauses: 5.18 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 74 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-19; its Internal attestation Type II covers "Identification & Authentication".

IAC-20 - Access Enforcement

ISO clauses: 5.18, 8.18 | Domain: Identification & Authentication | Status: Deficient | Responsibility: Enterprise | Assurance: 59 | Evidence records: 7

5 of 25 instances verified, 2 partial, 18 with no evidence collected. Worst result from Vanta - authorization policy test.

IAC-21 - Least Privilege

ISO clauses: 5.15, 5.18, 8.3, 8.12, 8.2 | Domain: Identification & Authentication | Status: Deficient | Responsibility: Enterprise | Assurance: 40 | Evidence records: 8

0 of 25 instances verified, 7 partial, 1 not implemented, 17 with no evidence collected. Worst result from AWS IAM Access Analyzer.

IAC-22 - Account Lockout

ISO clauses: 8.1 | Domain: Identification & Authentication | Status: Inherited | Responsibility: Enterprise | Assurance: 74 | Evidence records: 0

Enterprise Identity & Access Program operates IAC-22; its Internal attestation Type II covers "Identification & Authentication".

IRO-01 - Incident Response Operations

ISO clauses: 5.24 | Domain: Incident Response | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0

Enterprise Incident Response Program operates IRO-01; its Internal attestation Type II covers "Incident Response".

IRO-02 - Incident Handling

ISO clauses: 5.24, 5.25, 5.26, 6.8 | Domain: Incident Response | Status: Partial | Responsibility: Enterprise | Assurance: 65 | Evidence records: 0

0 of 1 instance verified, 1 partial. Worst result from Incident response tabletop exercise.

IRO-04 - Incident Response Plan (IRP)

ISO clauses: 5.24, 5.26, 5.25 | Domain: Incident Response | Status: Inherited | Responsibility: Enterprise | Assurance: 68 | Evidence records: 0

Enterprise Incident Response Program operates IRO-04; its Internal attestation Type II covers "Incident Response".

IRO-05 - Incident Response Training

ISO clauses: 5.29 | Domain: Incident Response | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0

Enterprise Incident Response Program operates IRO-05; its Internal attestation Type II covers "Incident Response".

IRO-06 - Incident Response Testing

ISO clauses: 5.30, 5.29 | Domain: Incident Response | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0

Enterprise Incident Response Program operates IRO-06; its Internal attestation Type II covers "Incident Response".

IRO-07 - Integrated Security Incident Response Team (ISIRT)

ISO clauses: 5.25, 5.26 | Domain: Incident Response | Status: Inherited | Responsibility: Enterprise | Assurance: 68 | Evidence records: 0

Enterprise Incident Response Program operates IRO-07; its Internal attestation Type II covers "Incident Response".

IRO-08 - Chain of Custody & Forensics

ISO clauses: 5.26, 5.28 | Domain: Incident Response | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0

Enterprise Incident Response Program operates IRO-08; its Internal attestation Type II covers "Incident Response".

IRO-09 - Situational Awareness For Incidents

ISO clauses: 5.25 | Domain: Incident Response | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0
Enterprise Incident Response Program operates IRO-09; its Internal attestation Type II covers "Incident Response".

IRO-10 - Incident Stakeholder Reporting

ISO clauses: 6.8, 8.8, 5.20 | Domain: Incident Response | Status: Inherited | Responsibility: Enterprise | Assurance: 68 | Evidence records: 0
Enterprise Incident Response Program operates IRO-10; its Internal attestation Type II covers "Incident Response".

IRO-11 - Incident Reporting Assistance

ISO clauses: 5.29 | Domain: Incident Response | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0
Enterprise Incident Response Program operates IRO-11; its Internal attestation Type II covers "Incident Response".

IRO-13 - Root Cause Analysis (RCA) & Lessons Learned

ISO clauses: 5.24, 5.27 | Domain: Incident Response | Status: Inherited | Responsibility: Enterprise | Assurance: 68 | Evidence records: 0
Enterprise Incident Response Program operates IRO-13; its Internal attestation Type II covers "Incident Response".

IAO-01 - Information Assurance (IA) Operations

ISO clauses: 5.21 | Domain: Information Assurance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

IAO-02 - Assessments

ISO clauses: 5.21, 5.23, 8.29 | Domain: Information Assurance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

IAO-04 - Threat Analysis & Flaw Remediation During Development

ISO clauses: 8.25 | Domain: Information Assurance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

MNT-01 - Maintenance Operations

ISO clauses: 7.13 | Domain: Maintenance | Status: Inherited | Responsibility: Vendor | Assurance: 78 | Evidence records: 0
AWS operates MNT-01; its SOC 2 Type II covers "Maintenance".

MNT-02 - Controlled Maintenance

ISO clauses: 7.13 | Domain: Maintenance | Status: Inherited | Responsibility: Vendor | Assurance: 68 | Evidence records: 0
AWS operates MNT-02; its SOC 2 Type II covers "Maintenance".

MNT-03 - Timely Maintenance

ISO clauses: 7.13 | Domain: Maintenance | Status: Inherited | Responsibility: Vendor | Assurance: 78 | Evidence records: 0
AWS operates MNT-03; its SOC 2 Type II covers "Maintenance".

MDM-01 - Centralized Management Of Mobile Devices

ISO clauses: 8.1 | Domain: Mobile Device Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

MDM-02 - Access Control For Mobile Devices

ISO clauses: 8.1 | Domain: Mobile Device Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

MDM-05 - Remote Purging

ISO clauses: 8.1 | Domain: Mobile Device Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

NET-01 - Network Security Controls (NSC)

ISO clauses: 5.14, 8.12, 8.20, 8.21 | Domain: Network Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

NET-02 - Layered Network Defenses

ISO clauses: 8.20 | Domain: Network Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

NET-03 - Boundary Protection

ISO clauses: 8.20, 8.21, 8.12 | Domain: Network Security | Status: Partial | Responsibility: Shared | Assurance: 55 | Evidence records: 3

2 of 6 instances verified, 1 partial, 3 with no evidence collected.

NET-04 - Data Flow Enforcement - Access Control Lists (ACLs)

ISO clauses: 5.14, 8.3, 8.20 | Domain: Network Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

NET-06 - Network Segmentation (macrosegmentation)

ISO clauses: 8.20, 8.22 | Domain: Network Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

NET-08 - Network Intrusion Detection / Prevention Systems (NIDS / NIPS)

ISO clauses: 8.21, 8.20 | Domain: Network Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

NET-13 - Electronic Messaging

ISO clauses: 5.14 | Domain: Network Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

NET-14 - Remote Access

ISO clauses: 6.7, 7.9 | Domain: Network Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

NET-15 - Wireless Networking

ISO clauses: 8.21 | Domain: Network Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

NET-18 - DNS & Content Filtering

ISO clauses: 5.14, 8.23 | Domain: Network Security | Status: Unassessed | Responsibility: Shared | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PES-01 - Physical & Environmental Protections

ISO clauses: 5.14, 5.15, 5.18, 7.1, 7.5 | Domain: Physical & Environmental Security | Status: Inherited | Responsibility: Vendor | Assurance: 66 | Evidence records: 0

AWS operates PES-01; its SOC 2 Type II covers "Physical & Environmental Security".

PES-02 - Physical Access Authorizations

ISO clauses: 5.15, 5.18, 7.1 | Domain: Physical & Environmental Security | Status: Inherited | Responsibility: Vendor | Assurance: 66 | Evidence records: 0

AWS operates PES-02; its SOC 2 Type II covers "Physical & Environmental Security".

PES-03 - Physical Access Control

ISO clauses: 5.15, 5.18, 7.1, 7.4, 7.2 | Domain: Physical & Environmental Security | Status: Inherited | Responsibility: Vendor | Assurance: 66 | Evidence records: 0

AWS operates PES-03; its SOC 2 Type II covers "Physical & Environmental Security".

PES-04 - Physical Security of Offices, Rooms & Facilities

ISO clauses: 5.15, 7.1, 7.3, 7.5, 7.7, 7.2, 7.6 | Domain: Physical & Environmental Security | Status: Inherited | Responsibility: Vendor | Assurance: 66 | Evidence records: 0

AWS operates PES-04; its SOC 2 Type II covers "Physical & Environmental Security".

PES-05 - Monitoring Physical Access

ISO clauses: 7.4 | Domain: Physical & Environmental Security | Status: Inherited | Responsibility: Vendor | Assurance: 66 | Evidence records: 0

AWS operates PES-05; its SOC 2 Type II covers "Physical & Environmental Security".

PES-06 - Visitor Control

ISO clauses: 7.2 | Domain: Physical & Environmental Security | Status: Inherited | Responsibility: Vendor | Assurance: 66 | Evidence records: 0

AWS operates PES-06; its SOC 2 Type II covers "Physical & Environmental Security".

PES-07 - Supporting Utilities

ISO clauses: 7.11, 7.12 | Domain: Physical & Environmental Security | Status: Inherited | Responsibility: Vendor | Assurance: 66 | Evidence records: 0

AWS operates PES-07; its SOC 2 Type II covers "Physical & Environmental Security".

PES-10 - Delivery & Removal

ISO clauses: 7.2 | Domain: Physical & Environmental Security | Status: Inherited | Responsibility: Vendor | Assurance: 66 | Evidence records: 0

AWS operates PES-10; its SOC 2 Type II covers "Physical & Environmental Security".

PES-12 - Equipment Siting & Protection

ISO clauses: 7.12, 7.3, 7.5, 7.8 | Domain: Physical & Environmental Security | Status: Inherited | Responsibility: Vendor | Assurance: 66 | Evidence records: 0

AWS operates PES-12; its SOC 2 Type II covers "Physical & Environmental Security".

PES-13 - Information Leakage Due To Electromagnetic Signals Emanations

ISO clauses: 8.12 | Domain: Physical & Environmental Security | Status: Inherited | Responsibility: Vendor | Assurance: 66 | Evidence records: 0

AWS operates PES-13; its SOC 2 Type II covers "Physical & Environmental Security".

PRM-01 - Security, Compliance & Resilience Protection Portfolio Management

ISO clauses: 5.1(e), 5.4, 5.8 | Domain: Project & Resource Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PRM-02 - Security, Compliance & Resilience Resource Management

ISO clauses: 5.1(c), 7.1, 5.4 | Domain: Project & Resource Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PRM-04 - Security, Compliance & Resilience In Project Management

ISO clauses: 5.8 | Domain: Project & Resource Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PRM-05 - Security, Compliance & Resilience Requirements Definition

ISO clauses: 5.8, 5.9, 8.26 | Domain: Project & Resource Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

PRM-07 - Secure Development Life Cycle (SDLC) Management

ISO clauses: 5.8, 8.25, 8.32 | Domain: Project & Resource Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

RSK-01 - Risk Management Program

ISO clauses: 6.1.1, 6.1.1(a), 6.1.1(b), 6.1.1(c), 6.1.1(d), 6.1.1(e)(1), 6.1.1(e)(2), 6.1.2, 6.1.2(a), 6.1.2(a)(1), 6.1.2(a)(2), 6.1.2(b), 6.1.2(c), 6.1.2(c)(1), 6.1.2(c)(2), 6.1.2(d), 6.1.2(d)(1), 6.1.2(d)(2), 6.1.2(d)(3), 6.1.2(e), 6.1.2(e)(1), 6.1.2(e)(2), 8.2, 7.5, 5.8 | Domain: Risk Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

RSK-02 - Risk-Based Security Categorization

ISO clauses: 6.1.2(d)(3) | Domain: Risk Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

RSK-03 - Risk Identification

ISO clauses: 6.1.2(c), 6.1.2(c)(1), 6.1.2(c)(2), 5.8 | Domain: Risk Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

RSK-04 - Risk Assessment

ISO clauses: 6.1.2(d), 6.1.2(d)(1), 6.1.2(d)(2), 6.1.2(d)(3), 6.1.2(e), 6.1.2(e)(1), 6.1.2(e)(2), 8.2, 5.8, 7.5 | Domain: Risk Management | Status: Partial | Responsibility: Internal | Assurance: 63 | Evidence records: 0

0 of 1 instance verified, 1 partial. Worst result from Annual enterprise risk assessment.

RSK-06 - Risk Remediation

ISO clauses: 6.1.3, 6.1.3(a), 6.1.3(b), 6.1.3(c), 6.1.3(d), 6.1.3(e), 6.1.3(f), 8.3, 5.8 | Domain: Risk Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

RSK-08 - Business Impact Analysis (BIA)

ISO clauses: 5.30 | Domain: Risk Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

RSK-09 - Supply Chain Risk Management (SCRM) Plan

ISO clauses: 5.21, 8.30 | Domain: Risk Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

RSK-10 - Data Protection Impact Assessment (DPIA)

ISO clauses: 5.33 | Domain: Risk Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

SEA-01 - Secure Engineering Principles

ISO clauses: 8.12, 8.26, 8.27 | Domain: Secure Engineering & Architecture | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

SEA-02 - Alignment With Enterprise Architecture

ISO clauses: 5.8, 8.26, 3.0, 3.1, 3.2 | Domain: Secure Engineering & Architecture | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

SEA-17 - Secure Log-On Procedures

ISO clauses: 8.5 | Domain: Secure Engineering & Architecture | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

SEA-20 - Clock Synchronization

ISO clauses: 8.17 | Domain: Secure Engineering & Architecture | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

SAT-01 - Security, Compliance & Resilience-Minded Workforce

ISO clauses: 7.4, 7.4(a), 7.4(b), 7.4(c), 7.4(d), 6.3 | Domain: Security Awareness & Training | Status: Inherited | Responsibility: Enterprise | Assurance: 65 | Evidence records: 0

Enterprise People Security Program operates SAT-01; its Internal attestation type-1 covers "Security Awareness & Training".

SAT-02 - Security, Compliance & Resilience Awareness Training

ISO clauses: 7.4, 7.4(a), 7.4(b), 7.4(c), 7.4(d), 6.3 | Domain: Security Awareness & Training | Status: Inherited | Responsibility: Enterprise | Assurance: 65 | Evidence records: 0

Enterprise People Security Program operates SAT-02; its Internal attestation type-1 covers "Security Awareness & Training".

SAT-03 - Role-Based Security, Compliance & Resilience Training

ISO clauses: 5.4, 6.3 | Domain: Security Awareness & Training | Status: Inherited | Responsibility: Enterprise | Assurance: 55 | Evidence records: 0

Enterprise People Security Program operates SAT-03; its Internal attestation type-1 covers "Security Awareness & Training".

OPS-01 - Operations Security

ISO clauses: 8.1, 5.37 | Domain: Security Operations | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

OPS-03 - Service Delivery (Business Process Support)

ISO clauses: 8.1, 5.37 | Domain: Security Operations | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-01 - Security, Compliance & Resilience Program (SCRP)

ISO clauses: 4.4, 5.1, 5.1(a), 5.1(b), 5.1(c), 5.1(d), 5.1(e), 5.1(f), 5.1(g), 5.1(h), 6.1.1, 6.1.1(a), 6.1.1(b), 6.1.1(c), 6.1.1(d), 6.1.1(e)(1), 6.1.1(e)(2), 8.1, 10.1, 5.4, 5.37, 5.3, 5.3(a), 5.3(b), 9.3.1, 9.3.2(a), 9.3.2(b), 9.3.2(c), 9.3.2(d), 9.3.2(d)(1), 9.3.2(d)(2), 9.3.2(d)(3), 9.3.2(d)(4), 9.3.2(e), 9.3.2(f), 9.3.2(g), 9.3.3, 7.4, 7.4(a), 7.4(b), 7.4(c), 7.4(d), 9.1, 9.1(a), 9.1(b), 9.1(c), 9.1(d), 9.1(e), 9.1(f) | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-02 - Publishing Security, Compliance & Resilience Documentation

ISO clauses: 5.1(a), 5.2, 5.2(a), 5.2(b), 5.2(c), 5.2(d), 5.2(e), 5.2(f), 5.2(g), 7.5.1, 7.5.1(a), 7.5.1(b), 7.5.2, 7.5.2(a), 7.5.2(b), 7.5.2(c), 7.5.3, 7.5.3(a), 7.5.3(b), 7.5.3(c), 7.5.3(d), 7.5.3(e), 7.5.3(f), 5.1, 5.37 | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-03 - Periodic Review & Update of Security, Compliance & Resilience Program

ISO clauses: 7.5.2, 7.5.2(a), 7.5.2(b), 7.5.2(c), 5.1, 5.37 | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-04 - Assigned Security, Compliance & Resilience Responsibilities

ISO clauses: 5.1(f), 5.1(h), 5.3, 5.3(a), 5.3(b), 5.2 | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-05 - Measures of Performance

ISO clauses: 9.1, 9.1(a), 9.1(b), 9.1(c), 9.1(d), 9.1(e), 9.1(f) | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-06 - Contacts With Authorities

ISO clauses: 5.5 | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-07 - Contacts With Groups & Associations

ISO clauses: 5.6 | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-08 - Defining Business Context & Mission

ISO clauses: 4.1, 4.2(a), 4.3, 5.1 | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-09 - Define Control Objectives

ISO clauses: 4.1, 4.2, 4.2(b), 4.2(c), 5.2(b), 6.2, 6.2(a), 6.2(b), 6.2(c), 6.2(d), 6.2(e), 6.2(f), 6.2(g), 6.2(h), 6.2(i), 6.2(j), 6.2(k), 6.2(l) | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-10 - Data Governance

ISO clauses: 5.12 | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

GOV-15 - Operationalizing Security, Compliance & Resilience Capabilities

ISO clauses: 9.2.2 | Domain: Security, Compliance & Resilience Governance | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TDA-01 - Technology Development & Acquisition

ISO clauses: 8.25, 8.30 | Domain: Technology Development & Acquisition | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TDA-02 - Minimum Viable Product (MVP) Security Requirements

ISO clauses: 8.25, 8.29, 8.30 | Domain: Technology Development & Acquisition | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TDA-05 - Developer Architecture & Design

ISO clauses: 8.27, 8.30 | Domain: Technology Development & Acquisition | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TDA-06 - Secure Software Development Practices (SSDP)

ISO clauses: 8.25, 8.26, 8.27, 8.28, 8.30, 8.29 | Domain: Technology Development & Acquisition | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TDA-07 - Secure Development Environments

ISO clauses: 8.25, 8.31 | Domain: Technology Development & Acquisition | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TDA-08 - Separation of Development, Testing and Operational Environments

ISO clauses: 8.25, 8.31 | Domain: Technology Development & Acquisition | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TDA-09 - Security, Compliance & Resilience Testing Throughout Development

ISO clauses: 8.25, 8.29, 8.30 | Domain: Technology Development & Acquisition | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TDA-10 - Use of Live Data

ISO clauses: 8.33 | Domain: Technology Development & Acquisition | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TDA-14 - Developer Configuration Management

ISO clauses: 8.30, 8.32 | Domain: Technology Development & Acquisition | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TDA-20 - Access to Program Source Code

ISO clauses: 8.4, 8.30 | Domain: Technology Development & Acquisition | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TPM-01 - Third-Party Management

ISO clauses: 5.19, 5.20, 8.30 | Domain: Third-Party Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TPM-02 - Third-Party Criticality Assessments

ISO clauses: 5.19 | Domain: Third-Party Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TPM-03 - Supply Chain Risk Management (SCRM)

ISO clauses: 5.19, 5.21, 5.22, 8.30, 5.2 | Domain: Third-Party Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TPM-04 - Third-Party Services

ISO clauses: 5.19, 8.30, 5.21 | Domain: Third-Party Management | Status: Partial | Responsibility: Internal | Assurance: 65 | Evidence records: 0

0 of 1 instance verified, 1 partial. Worst result from Vendor reassessment backlog report.

TPM-05 - Third-Party Contract Requirements

ISO clauses: 5.19, 5.20, 5.21, 5.31, 6.6, 8.21, 8.30, 4.3(c), 5.2, 5.23 | Domain: Third-Party Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TPM-06 - Third-Party Personnel Security

ISO clauses: 5.2, 5.19, 8.30 | Domain: Third-Party Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TPM-08 - Review of Third-Party Services

ISO clauses: 5.19, 5.20, 5.22, 8.21 | Domain: Third-Party Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TPM-09 - Third-Party Deficiency Remediation

ISO clauses: 5.19 | Domain: Third-Party Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TPM-10 - Managing Changes To Third-Party Services

ISO clauses: 5.20, 5.22 | Domain: Third-Party Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

TPM-11 - Third-Party Incident Response & Recovery Capabilities

ISO clauses: 5.19 | Domain: Third-Party Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

THR-01 - Threat Intelligence Program

ISO clauses: 5.7 | Domain: Threat Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

THR-02 - Indicators of Exposure (IOE)

ISO clauses: 5.7 | Domain: Threat Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

THR-03 - Threat Intelligence Feeds

ISO clauses: 7.4, 7.4(a), 7.4(b), 7.4(c), 7.4(d), 5.7 | Domain: Threat Management | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0

Applicable, but outside the declared assessment scope. No assurance score has been asserted.

VPM-01 - Vulnerability & Patch Management Program (VPMP)

ISO clauses: 8.8 | Domain: Vulnerability & Patch Management | Status: Inherited | Responsibility: Enterprise | Assurance: 68 | Evidence records: 0

Enterprise Security Operations Program operates VPM-01; its Internal attestation Type II covers "Vulnerability & Patch Management".

VPM-02 - Vulnerability Remediation Process
ISO clauses: 8.8 | Domain: Vulnerability & Patch Management | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0
Enterprise Security Operations Program operates VPM-02; its Internal attestation Type II covers "Vulnerability & Patch Management".

VPM-03 - Vulnerability Ranking
ISO clauses: 8.8 | Domain: Vulnerability & Patch Management | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0
Enterprise Security Operations Program operates VPM-03; its Internal attestation Type II covers "Vulnerability & Patch Management".

VPM-05 - Software & Firmware Patching
ISO clauses: 8.8 | Domain: Vulnerability & Patch Management | Status: Partial | Responsibility: Enterprise | Assurance: 83 | Evidence records: 5
3 of 5 instances verified, 2 partial. Worst result from Tenable - production scan.

VPM-06 - Vulnerability Scanning
ISO clauses: 8.8 | Domain: Vulnerability & Patch Management | Status: Inherited | Responsibility: Enterprise | Assurance: 78 | Evidence records: 0
Enterprise Security Operations Program operates VPM-06; its Internal attestation Type II covers "Vulnerability & Patch Management".

WEB-02 - Use of Demilitarized Zones (DMZ)
ISO clauses: 8.22 | Domain: Web Security | Status: Unassessed | Responsibility: Internal | Assurance: Unassessed | Evidence records: 0
Applicable, but outside the declared assessment scope. No assurance score has been asserted.

8. Findings and Plan of Action

Open findings and remediation commitments associated with this system boundary.

Finding	Severity	Control	Owner	Due	Status
Scope RAG service's IAM role to least privilege	Not recorded	IAC-21	ML Platform Team	2026-08-25	In Progress
Deploy DLP scanning on the prod-customer-data ingestion path	high	NET-17	S. Patel	2026-09-05	Planned
Define retention/disposal schedule for vector embeddings and the RAG document store	medium	DCH-18	ML Platform Team	2026-09-15	Planned

9. Supplemental Assurance

Practices represented in this application that extend beyond a narrow control checklist.

- PRISMA maturity separates policy, procedure, implementation, measurement, and managed operation.
- Assurance and assessment coverage are reported separately so an assessed subset is not mistaken for full coverage.
- Control evidence is linked to system and asset context, with stale evidence explicitly identified.
- Agentic identities, autonomy, credential age, privilege, logging, ownership, and revocation are assessed as first-class identity signals.
- Architecture, data movement, software delivery, backup, and recovery are represented as operational system facts.
- Residual risk is compared with risk appetite and linked to control assurance and remediation.

10. Report Limitations

Interpretation guidance for reviewers and decision-makers.

- This is a system-level assurance report generated from the application's current fictional demo data.
- It is not an ISO/IEC 27001 certificate, certification audit result, legal opinion, or proof of conformity.

- It is not a complete organization-wide Statement of Applicability. Not-applicable and pending decisions require governance approval and rationale outside this report.
- ISO clause identifiers reflect the application's imported crosswalk. This report does not reproduce ISO normative control text.
- Unassessed means applicable but not examined in the declared assessment scope; it is intentionally not represented as a zero score.